

联易融智能合约安全审计规范制度

1. 背景

智能合约是一种基于区块链技术的智能程序，是区块链开发的重要组成部分。智能合约允许在不需要一方人为保证的情况下自动信任和执行交易。高度自动化和去中心化的特性，吸引了大量企业和机构的注意，并被广泛应用于多个领域如：金融、保险、市场、变革，以及健康、物流和供应链等，这给许多企业带来了巨大的经济利益和商业机会。

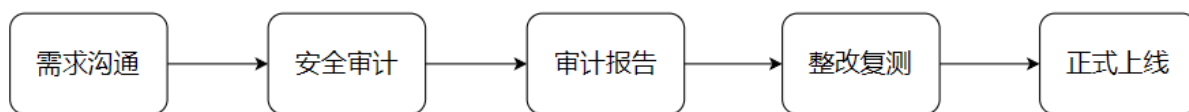
然而智能合约会存在一定的安全风险。一方面某些智能合约会存在安全漏洞；另一方面由于区块链技术的复杂性，代码审查和修复漏洞时间都较长，为攻击者提供了可乘之机。而这些在智能合约中出现的漏洞可能会产生许多我们意想不到的后果，例如：在合约中的资产突然被转移到错误的账户，或者交易未能自动执行，导致损失等。

考虑到这些安全风险，智能合约安全审计变得越来越重要。安全审计内容主要包括审计智能合约的代码是否可以被恶意解析器利用、是否会被破坏等方面。而审计团队的任务则是确定不规范的代码逻辑、未定义的操作、代码注入漏洞以及需要更新和修改的其他安全问题。

智能合约的安全审计工作能为用户提供更高的信赖和安全性。对于企业和机构，智能合约的安全审计可以减少技术风险并提高产品的竞争力，同时可以增强合同的规范性和可信性，以保护各方的利益和资产。因此，智能合约的安全审计将在区块链技术的发展中发挥越来越重要的作用，也将成为未来区块链基础建设中必不可少的环节。

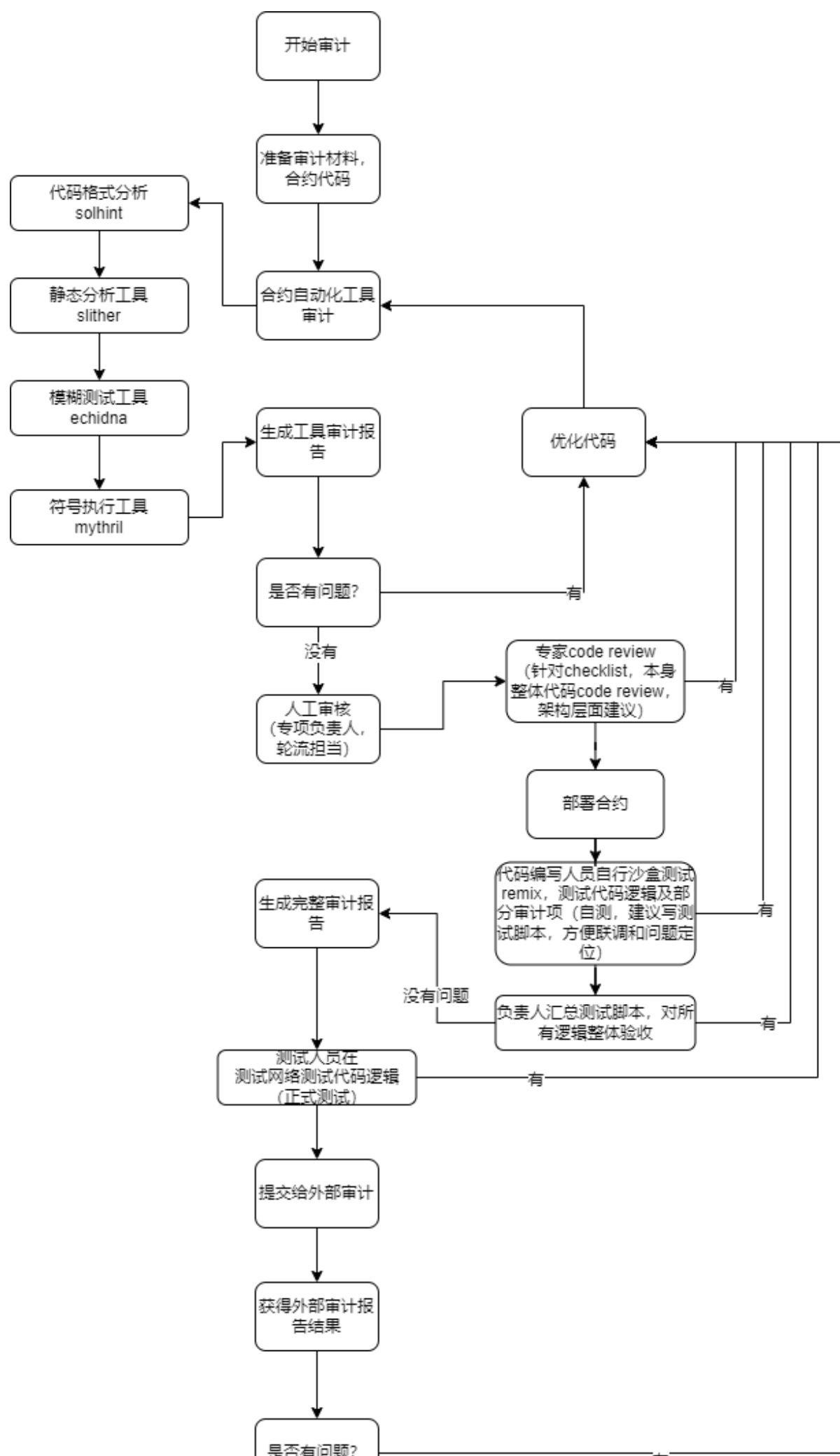
2. 审计整体流程

一般来说，合约审计的整体流程如下：



- **需求沟通**：需要与业务方沟通，确保审计方和业务方在目标、规则、合约性质等方面的理解一致
- **安全审计**：识别智能合约中的安全漏洞和问题，分为自动化审计以及人工审计两步，是合约审计最重要也是最核心的部分
- **审计报告**：对审计结果进行总结和说明，并提供相应的解决方案和建议，以便审计方和业务方更好地了解合约的安全性和稳定性
- **整改复测**：根据审计报告结果中的合约漏洞，进行相应的修复，并重复进行审计和测试，以确保合约最终的安全性和稳定性
- **正式上线**：确定合约没有安全问题后，正式部署到公链上

根据上述内容，我们制定了联易融内部的智能合约安全审计流程：



所图所示，在每个业务迭代中，会按照几个阶段进行合约审计：

1. **准备阶段**：准备审计材料，包括：合约源码，需求文档等
2. **自动化审计**：通过合约审计工具，进行自动化审计，并生成审计报告
3. **人工审计**：通过人工进行审计，在自动化审计报告的基础上，生成人工审计报告
4. **整改复测**：根据审计报告结果中的合约漏洞，进行相应的修复，并重复进行审计和测试
5. **沙盒测试**：通过在模拟的，与现实环境隔离的环境中运行合约代码，来发现潜在漏洞和安全风险的测试方法。沙盒测试可以避免在实际运行环境中可能出现的安全威胁，并为开发人员提供一个相对安全的环境，以测试其 Solidity 智能合约的正确性和可行性
6. **负责人测试验收**：完成针对 Solidity 智能合约的各项测试后，对其进行全面的确认和验证，以保证其在实际运行环境中的安全性、可靠性和正确性。整体验收通常需要一系列操作和步骤，并对测试结果进行逐一确认。并最终生成完整的审计报告
7. **测试代码逻辑**：主要交予公司测试人员对业务逻辑进行全面测试
8. **外部审计**：内部审计没有问题后，根据业务需求进行外部审计（可选）。外部审计是由独立的专业机构或个人对 Solidity 智能合约进行全面的审查和评估，并提供审计报告和修复建议的过程。外部审计团队通常由一些资深的区块链安全专家、加密货币经济学家、密码学家组成，依据自己的审计标准，对合约的代码、设计、逻辑、安全性等进行全面评估，以尽可能地发现所有潜在的安全漏洞和问题。外部审计通常需要开发者提供合约源代码和测试环境，审计结果一般由第三方审计机构或团队出具审核报告。

接下来将展开介绍安全审计以及审计报告这两个最核心的内容。

3. 安全审计（核心步骤）

作为审计流程中最重要的一环，安全审计主要包括自动化审计以及人工审计两部分，通过这两部分能覆盖所有检查项 checklist，同时自动化审计项占比 80%，能极大地提高审计的效率，缩短审计时间。接下来将分别介绍 checklist、自动审计以及人工审计的具体内容。

3.1 checklist

作为审计前的准备，最主要是准备检查项的 checklist。checklist 的主要作用是帮助合约审计师系统地评估智能合约的安全性和正确性，清单包含一系列需要检查的核心要素，包括：

- 名称：审计项的具体名称
- 分类：包括技术分类（变量，数据结构，函数，修饰符，整体代码，外部调用，静态调用，事件，合约）以及功能分类（访问控制，继承的正确性，外部交互，状态机，标准的一致性，算术运算，书写规范）
- 内容：审计项的具体内容

- 错误级别：审计项的错误级别，分为高，中，低三级
- 审计方式：分为工具及人工审计两种
- 具体方法：工具审计的命令行方法
- 错误示范：对应错误示范代码
- 错误信息：针对错误释放代码工具提示的错误信息
- 修改建议：针对错误项的修改建议方案

在进行区块链技术的应用开发之前，使用审核清单可以最大程度保障合约的稳健性和可靠性，并消除潜在的漏洞风险，降低项目失败和投资损失的风险。在参考了社区主流开源方案

([GitHub - tamjid0x01/SmartContracts-audit-checklist: A checklist of things to look for when auditing Solidity smart contracts.](https://github.com/tamjid0x01/SmartContracts-audit-checklist)) 的基础上，我们结合联易融区块链跨境贸易单据场景以及跨境数字资产结算场景的业务特点，制定了一套 checklist ([合约审计 checklist](#))，作为公司合约安全审计的参考标准：

1	审查项	分类	细项	slither检查项	内容	错误级别	审核方式	使用工具
2	变量 (variable)	状态机	V4		变量是否可见 (SWC-108)	高	工具	solhint
3		访问控制	V11	abienncoderV2-array	存储 ABIEncoderV2 数组	高	工具	slither
4		访问控制	V12	protected-vars	检测标记为受保护的未受保护变量	高	工具	slither
5		算术运算	V13	rtlo	攻击者可以通过使用从右到左的覆盖字符 (SW-130)	高	工具	slither
6		状态机	V14	uninitialized-state	未初始化的状态变量(SWC-109)	高	工具	slither
7	数据结构	状态机	V15	uninitialized-storage	未初始化的存储变量将充当对第一个状态变量的引用，并且可以覆盖关键变量(SWC-109)	高	工具	slither
8		状态机	S4	public-mappings-nested	具有嵌套结构的公共映射返回不正确值	高	工具	slither
9	函数	访问控制	F5		函数是否只能由受信任的用户调用	高	人工	code review
10		访问控制	F6	reentrancy-eth, reentrancy-no-eth	函数是否遵循效果模式之前的检查 (SWC-107)	高	工具	slither
11		访问控制	F7		函数是否有抢先交易的可能性 (SWC-114)	高	人工	code review
12		状态机	F8		函数是否会出现gas不足 (SWC-126)	高	人工	沙盒测试
13	外部调用		F20		含注重大小写如果存在子合约可能覆盖函数行为的合法（且安全）实例，则使用	低	工具	solhint

该 checklist 包含的审计类型有：

- 变量：审计合约中的变量是否有安全风险，如是否可以作为 internal 等
- 数据结构：审计合约中的数据结构是否有安全风险，如结构体的字段是否可以合并在一起
- 函数：审计合约中的函数是否有安全风险，如是否有抢先交易的可能性，是否会出现 gas 不足等
- 修饰符：审计合约中的修饰符是否有安全风险，如是否进行存储更新
- 整体代码：审计合约中的整体代码是否有安全风险，如是否使用 nonce 和 block.chainid 保护签名免于重播等
- 外部调用：审计合约中的外部调用是否有安全风险，如是否会出现重入等
- 静态调用：审计合约中的静态调用是否有安全风险，如进入无限循环，是否会导致 DoS
- 事件：审计合约中的事件是否有安全风险，如是否在发出事件的函数中操作的所有用户/ID 都存储为索引字段等
- 合约：审计合约中的合约是否有安全风险，如是否使用了正确的 SPDX 合约标识符等

- Defi: 审计合约中的 Defi 使用是否有安全风险，如是否使用健全性检查来防止价格操纵等
- 根据审计方式又可分为工具审计和人工审计两种方式。工具审计通过自动化审计工具得出结果，而人工审计则是需要通过人工的方式进行审计操作。

3.2 合约自动化审计

合约自动化审计也即通过开源审计工具，对合约进行代码审计，并生成审计报告，目前使用的审计工具如下：

- solhint：一款免费开源的 JavaScript 工具 ([GitHub - protofire/solhint: Solhint is an open-source project to provide a linting utility for Solidity code.](#))，为 Solidity 智能合约开发人员提供代码格式化，标准化服务
- slither：一款免费开源的静态分析工具 ([GitHub - crytic/slither: Static Analyzer for Solidity](#))，专门用于检测 Solidity 智能合约的安全漏洞和潜在问题，并提供相应的修复建议。它能够对合约代码进行深入分析，识别出可能导致漏洞的原因和风险，为 Solidity 合约开发人员提供安全保障。slither 是目前最强大的合约审计工具，能够基于语义提供全面的安全漏洞分析，包含的中高等级风险项目数有将近 50 个，覆盖 checklist 工具检查项的 76%
- echidna：一款基于 Fuzzing 技术的智能合约测试工具 ([GitHub - crytic/echidna: Ethereum smart contract fuzzer](#))，可自动生成随机测试用例对 Solidity 智能合约进行测试，发现合约中的安全漏洞和错误
- mythrill：一款免费开源的智能合约安全分析工具 ([GitHub - ConsenSys/mythrill: Security analysis tool for EVM bytecode. Supports smart contracts built for Ethereum, Hedera, Quorum, Vechain, Roostock, Tron and other EVM-compatible blockchains.](#))，使用基于符号执行的技术，模拟合约执行路径，自动化地分析 Solidity 智能合约中的潜在安全问题，包括不安全的代码模式、漏洞和攻击向量，并提供修复建议。作为 slither 的补充工具，它和 slither 的区别在于：由于其使用了符号执行技术，能够识别出一些 slither 无法识别的漏洞如 SWC-101, SWC-105, SWC-124 等

工具按如下顺序依次调用：

solhint -> slither -> echidna -> mythrill

我们将按照上述流程构建自动化审计工具链，提供审计客户端，并采用云原生的架构搭建自动化审计基础设施。而在使用工具链完成自动化审计后，会生成审计报告。目前工具审查项占比 80%，保障了自动化审计的高效性；同时高优先级占比 80%（高优先级的错误必须修复），保障了审计的高质量。通过“双高”特性落实了自动化合约审计的可执行性。

3.3 合约人工审计

虽然自动化审计能完成 80% 的审计项，但其它一些更加复杂且高阶的内容则需要人工介入。合约人工审计是一种基于经验和专业知识的智能合约安全审查方法，通过对 Solidity 代码的手动

审查和分析，寻找潜在的漏洞和安全风险，提供更为详细和深入的审查报告来保证智能合约的安全性和正确性。人工审计通常需要较高的技能和经验，能够全面实地检查合约的执行环境和数据流，以发现可能被自动化工具所忽略的潜在问题。具体实施步骤为根据 checklist 的人工审核项，一项一项进行核对，生成人工审计意见，给开发人员进行优化，而优化目标与自动化审计一致：高优先级全部解决，中低优先级检查项建议解决。

审查项	错误分类	细项	slither检查项	内容	错误级别	审核方式
函数 (function)	访问控制	F5		函数是否只能由受信任的用户调用	高	人工
	访问控制	F7		函数是否有抢先交易的可能性 (SWC-114)	高	人工
	状态机	F8		函数是否会出现gas不足 (SWC-126)	高	人工
修饰符 (modifier)	访问控制	M1		修饰符是否进行存储更新 (重入除外)	高	人工
整体代码 (Code)	状态机	C11		代码中是否使用了abi.encodePacked() (SWC-133)	高	人工
	状态机	C12		谨慎使用assembly, 对其内容进行排除, 防止内存访问错误(SWC-127)	高	人工
	访问控制	C32		代码中不要使用address.transfer()或address.send() (SWC-134)	高	人工
	访问控制	C33		使用底层的call接口调用, 需先确保合约存在 call/delegatecall/send	低	人工
	算术运算	C43		检查unchecked block部分是否存在上/下溢	高	人工
外部调用 (external call)	访问控制	X3		外部调用是否会出现重入	高	人工
静态调用 (static call)	外部交互	S4		如果查询调用进入无限循环, 是否会导致 DoS	高	人工
事件 (event)	状态机	E5		函数中操作的所有用户/ID 是否都在事件存储为索引字段	高	人工
合约 (contract)	标准的一致性	T1		使用正确的SPDX合约标识符	高	人工
DeFi		D1		DeFi业务逻辑单元测试, 测试结果是否满足要求	高	人工
		D9		确保token精度要求, token交易记录、手续费等重要信息记录在案。链上or链下	高	人工
		D10		避免通过地址持有的代币数量决定DeFi收益。	高	人工
		D11		避免用户重复调用approve token到合约	高	人工

4. 审计报告

审计报告是最终审计生成的结果，提供给合约开发人员、审计机构和投资者等参考，帮助他们快速了解合约的安全性和风险状况。在参考头部公司 consensys ([Public Smart Contract Audits and Security Reviews | ConsenSys Diligence](#)) 以及 openzeppelin ([OpenZeppelin Blog | Security audits](#)) 的报告设计后，我们制定了联易融安全审计对应的审计报告格式：

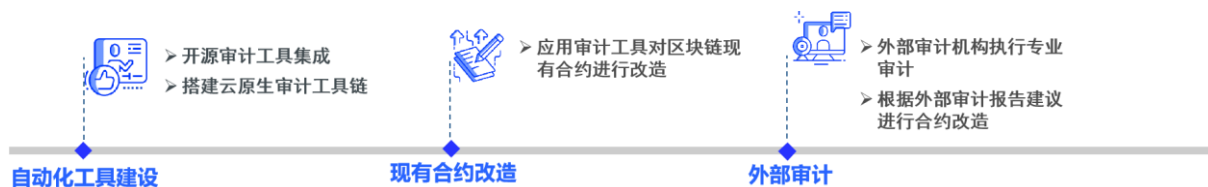
联易融审计报告

报告分为如下几个部分：

- **报告总结：**对审计背景、时间以及工作量做简要概括和总结
- **问题总览：**概括通过审计发现的问题，提供一份准确的问题数量统计清单
- **总体结构：**指导读者了解并检查审计代码的内容组织方式，帮助其快速定位所关心的合约问题相关的部分
- **错误项：**主要作用是列举并详细描述审计过程中发现的所有错误及漏洞，同时给出相应的修复建议，帮助合约开发者和审计机构优化并修复错误，从而提高合约的可靠性和安全性
- **人工评审意见：**对自动化审计结果的进一步补充，由专业的安全审计人员针对 checklist 人工检查项提供有针对性和实用性的安全建议

5. 实施计划

针对区块链业务，我们拟定了一个分阶段的实施计划，每个阶段里程碑：



1. 自动化工具建设：集成开源审计工具，构建基于云原生体系的自动化工具链，并提供操作指引，方便后续审计实施
2. 现有合约改造：利用自动化工具链对现有 Defi 相关合约进行审计，并根据审计流程对合约进行改造和上线
3. 外部审计：在内部改造完成后，如有必要可联系外部审计公司进行专业审计，并根据审计结果进行合约改造和上线

6. 内部合约安全审计意义

内部审计规范及工具链的建设对联易融区块链业务发展具有重大意义，不仅能增强区块链业务的规范性，同时也让用户和投资者能够更加信任联易融区块链产品的可靠性和安全性。而内部合约安全审计的具体作用也可归纳为两方面，一方面公司可完全依赖内部审计保障合约质量，避免在生产环境中出现严重的安全漏洞；另外一方面通过内部审计可解决大部分的安全问题，减少交付给外部审计机构的合约数以及后续问题修复的时间，降低外部审计的整体成本。

为了全面真实地评估内部审计的能力，我们调研了国际知名审计公司 Certik，并与联易融内部审计功能做了对比：

功能项	Certik	联易融
运算	有	有
访问控制	有	有
矿工操纵（通过控制算例来操纵结果）	有	无（以太坊这种大型的平台不会出现矿工操纵这种情况）
Dos	有	有
外部引用	有	有
重入	有	有
底层调用	有	有

可见性	有	有
接口错误	有	有

可以看到内部审计基本上覆盖了 Certik 公司的所有重要审计功能。而为了更加全面的分析对比审计能力，我们从专业性、准确度以及价格方面也做了一个综合对比：

	Certik	内部审计
专业性	高（有合约方面的专家把关）	中（公司暂时缺少这方面的专家）
准确性	高（有规范的审计流程，以及丰富的实践经验）	中（目前还在积累阶段，人工审计准确率较低）
价格	1 人天 3000 美金	免费

联易融在专业性以及准确度上都相对较差，需要时间和经验去培养合约审计这方面的专家。但相比高额的审计价格，我们是具备明显价格优势的。也即：内部审计基本可以覆盖外部审计公司的重要功能项，虽然质量上有一定的差距，但性价比高，可执行性强。同时随着时间的推移以及经验的积累，相信未来联易融内部审计能力会越来越好。

7. 总结

合约审计是区块链基础建设中至关重要的一部分，通过建设合约审计流程和制度，不仅能增强团队合约编写的规范性；同时可以检测合约中的潜在风险和漏洞，提高可靠性和安全性，减少损失，保护用户的利益。本文首先讲解了内部合约审计的全流程，之后依次介绍了安全审计的核心部分：checklist、自动化审计、人工审计以及审计报告等内容，最后解释了建设内部合约审计对区块链业务发展的重大意义。

随着区块链技术的发展和应用，合约审计会越来越重要，区块链开发团队会不断优化内部审计效率，提高审计质量；同时也会不断思考如何更好地与现有业务研发流程结合，更好更安全地为业务服务。